Stoquify Security Hardening Plan — 2026-07-28

Objective

Establish fail-closed tenant, authentication, authorization, entitlement, audit, token, public-access and integration boundaries while retaining service ownership.

Immediate containment

- Replace request-derived trusted origins with configured normalized origins.
- Deny unknown Host/forwarded-host inputs and test spoofing.
- Retain public-receipt signed token, registry, revocation, redaction and fresh-auth controls.

Structural program

1. Resolve ADR-0002 through scoped Prisma, tenant repositories or PostgreSQL RLS. Provide one named infrastructure escape and static raw-client gate.
2. Create an action/API/worker/service authorization matrix. Every external mutation declares permission, module, tenant source and fresh-auth/maker-checker needs.
3. Replace best-effort critical security audit with transactional append-only outbox obligations. Define which actions fail closed.
4. Store invite bearer tokens as HMAC/SHA-256 digests; display/send raw once; redeem via conditional one-time state transition; expire/revoke old plaintext material through reviewed migration.
5. Persist offline original actor at ingest. Automated replay uses a scoped worker identity; manual replay uses dedicated permission, entitlement and step-up policy.
6. Derive AI route/module/permission policy server-side and prohibit creator self-approval before executable proposals.
7. Add webhook/provider signature, timestamp, nonce/idempotency, replay window, quarantine and redacted diagnostics where integrations exist.
8. Wire external log/metric/alert transports and prove delivery, redaction, ownership and retention.

Mandatory tests

Cross-tenant direct/indirect IDs; missing permission/entitlement; spoofed host; audit outage; concurrent invitation redemption; stolen/legacy token migration; offline actor mismatch; webhook tamper/replay; redaction; AI permission mismatch/self-approval.

Rollout

Observe inventory → compatibility adapter → feature flag/deny gate → shadow assertions → enforce → remove legacy path. Rollback may disable new entry but must retain audit and correction evidence.

External blockers

Managed secrets, trusted-proxy configuration, provider signing specifications, production telemetry endpoint and statutory authority inputs are unverified.